HU.002 – AUTENTICAR USUÁRIO

PROJETO: Viabiliza — Sistema de Licenciamento Eletrônico

HISTÓRICO DE REVISÃO			
DATA	**RESUMO DAS ALTERAÇÕES**	**VERSÃO**	**Responsável**
16/10/2026	Revisão pelo código-fonte vigente	2.0	Sudoeste Informática

VISÃO GERAL

Catálogo Viabiliza: HU-002. O cidadão entra no portal com CPF e senha local. O servidor entra no console com e-mail ou usuário AD e senha, em sessão separada. Conta AD valida a credencial na API institucional da SEDUR e nunca cai para a senha local Regras evidenciadas no código: (1) RN-001: portal autentica por CPF; console autentica por e-mail ou ad_username (FortifyServiceProvider, LoginController::store). (2) RN-002: conta AD (User::isAdAccount, AuthType::Ad) só valida em DirectoryAuthenticator; o comentário e o código de credencialValida não consultam users.password. (3) RN-003: falha de credencial no console usa sempre __('auth.failed') ("As credenciais indicadas não coincidem com as registradas no sistema."), para conta inexistente, local ou AD (LoginController::store). (4) RN-004: inatividade, falta de acessar-gestao e e-mail não verificado só são informados depois da credencial correta. (5) RN-005: primeiro acesso AD persiste a conta e pode conceder acessar-gestao; a senha corporativa não é gravada (registrarPrimeiroAcessoAd). (6) RN-006: login, falha, bloqueio, inativação e indisponibilidade/sincronização AD geram access_logs (RecordSuccessfulLogin, RecordFailedLogin, RecordLockout e os AccessLog::create do LoginController). Fluxo evidenciado: 1. Fortify::authenticateUsing normaliza o CPF para dígitos e busca users.cpf 2. Se a conta não existe ou Hash::check falha, devolve null. O evento Failed vira registro falha em access_logs (RecordFailedLogin), sem dizer se a conta existe 3. Se a senha confere e inactivated_at está preenchido, grava o evento inativada e responde: "Sua conta está inativa. Procure o administrador do sistema." 4. Com credencial válida e conta ativa, a sessão do guard web é criada. LoginResponse descarta URL pretendida que comece com /gestao e redireciona para o destino pretendido ou portal.dashboard 5. O limite de tentativas vem de security.login.max_attempts (padrão 5), chave CPF (só dígitos) + IP. No bloqueio, o evento Lockout grava bloqueio (RecordLockout) 6. Sucesso grava access_logs.event = login, canal portal (RecordSuccessfulLogin) 1. LoginRequest exige identifier e password. O identificador é comparado em minúsculas com email ou ad_username 2. Se não há conta e SedurAuthSettings::enabled() (features.ad_login) está ligado, e o identificador não contém espaço, registrarPrimeiroAcessoAd chama SedurDirectoryAuthenticator::attempt. Credencial inválida segue como falha genérica. API indisponível grava ad-indisponivel e responde que a autenticação institucional está indisponível 3. Com a API aceitando o primeiro acesso, o sistema cria ou reaproveita o usuário por e-mail ou CPF, grava auth_type = ad, ad_username, senha local aleatória de 64 caracteres e email_verified_at. Se a conta ainda não pode acessar-gestao, concede essa permissão. Se a descoberta trouxer setor, UserSectorAssignmentSync::syncFromDiscovery tenta vincular; falha de sincronização grava ad-sincronizacao-falhou e não desfaz o login 4. Conta já existente valida a

credencial em credencialValida: local com Hash::check; AD de novo na API, sem usar o hash local. Com o interruptor AD desligado, conta AD recebe bloqueio auditado (AuditService::logBlocked) e a mensagem de autenticação corporativa desabilitada 5. Depois da credencial correta, nesta ordem: conta inativa (evento inativada e mensagem de conta inativa); sem acessar-gestao (bloqueio auditado e "Esta conta não tem acesso ao console de gestão."); e-mail não verificado ("Confirme seu e-mail institucional antes de acessar o console.") 6. Sucesso limpa os limitadores, faz login no guard gestao, regenera o id da sessão e redireciona ao destino interno ou ao painel. Com o cabeçalho X-Viabiliza-Login-Async, devolve JSON { destino } em vez de redirecionar na hora 7. O limite por conta usa security.login.max_attempts (identificador + IP). O limite por IP usa viabiliza.security.login.max_attempts_per_ip (padrão 30). Os dois disparam Lockout e a mensagem auth.throttle Não evidenciado no código: Não há segundo fator nem passkey nas features do Fortify (config/fortify.php lista registro, recuperação de senha, verificação de e-mail e atualização de senha). Não há autenticação AD no portal. O logout do portal não está neste controller.

SUMÁRIO

ÉPICO: EP01 — Identidade, Acesso e Segurança

HISTÓRIA DE USUÁRIO: Autenticar usuário

PRÉ-REQUISITOS

DEPENDÊNCIAS

INTERFACE DE USUÁRIO

TELA 1 - Autenticar usuário

COMPORTAMENTO ESPERADO TELA 1

APROVAÇÃO DO REQUISITO

ÉPICO: EP01 — Identidade, Acesso e Segurança

Como a SEDUR **quero** autenticar usuário**, de modo que** O cidadão entra no portal com CPF e senha local. O servidor entra no console com e-mail ou usuário AD e senha, em sessão separada. Conta AD valida a credencial na API institucional da SEDUR e nunca cai para a senha local.

HISTÓRIA DE USUÁRIO: Autenticar usuário

Como usuário com conta no Viabiliza **quero** entrar no portal ou no console com a credencial do meu ambiente**, de modo que** usar só o que a minha sessão e as minhas permissões permitem.

PRÉ-REQUISITOS

• Portal: visitante. Rotas do Fortify em /portal/login (guard web). Depois do login, as telas exigem auth:web, verified e, no grupo autenticado, lgpd.accepted

• Console: visitante em /gestao/login (gestao.guest). O POST é LoginController::store. O grupo interno exige auth:gestao, a permissão acessar-gestao e lgpd.accepted

• As duas sessões são independentes. O logout do console (LoginController::destroy) encerra só o guard gestao e regenera o token; não invalida a sessão inteira

• Não há item de menu para o login. O cabeçalho de cada ambiente aponta o logout da própria sessão

• Portal: campo de usuário do Fortify é cpf; a senha é a do formulário de login. Não há Form Request próprio

• Console, LoginRequest: identifier obrigatório, texto, máximo 255; password obrigatório, texto. O checkbox remember é lido com boolean('remember') e não entra nas regras

DEPENDÊNCIAS

Passadas

• Nenhuma além do que o código desta história já exige

Futuras

• Nenhuma

INTERFACE DE USUÁRIO

TELA 1 - Autenticar usuário

Caminho no menu: Conforme a permissão e a rota descritas nos pré-requisitos

[INSERIR PRINT DA TELA: Autenticar usuário]

COMPORTAMENTO ESPERADO TELA 1

Cenário 1: Comportamento evidenciado no código

Dado que o código desta história está como descrito na visão geral

Quando entrar no portal ou no console com a credencial do meu ambiente,

Então O cidadão entra no portal com CPF e senha local. O servidor entra no console com e-mail ou usuário AD e senha, em sessão separada. Conta AD valida a credencial na API institucional da SEDUR e nunca cai para a senha local

APROVAÇÃO DO REQUISITO

A Sudoeste Informática esclarece que o desenvolvimento das funcionalidades descritas neste documento foi realizado de acordo com os requisitos e especificações fornecidos pelo cliente. Nossa equipe seguiu rigorosamente as instruções recebidas, garantindo que o sistema esteja alinhado com o que foi solicitado.

Para evitar possíveis retrabalhos ou ajustes futuros, sugerimos que o cliente revise atentamente os requisitos apresentados, verificando se eles atendem plenamente às suas necessidades e expectativas, bem como se estão em conformidade com eventuais normas aplicáveis ao seu negócio.

Reafirmamos nosso compromisso de entregar um software de qualidade que agregue valor às operações do cliente, e a validação cuidadosa dos requisitos é um passo importante para garantir o sucesso do projeto.

APROVAÇÃO DO REQUISITO			
DATA	**SETOR**	**NOME**	**ASSINATURA**